

JemTechnologies — Network Security Team

Firewall Operations Runbook

Doc ID: NST-RB-003 | Version: 2.7 | Last Reviewed: 2026-07-08
Owner: Network Security Operations (NSO) | Classification: Internal Use Only

1. Purpose and Scope

This runbook is the operational reference for JemTechnologies Network Security Operations (NSO) engineers performing day-to-day firewall operations: rule implementation, NAT configuration, ACL management, rule ordering, logging configuration, and validation. It complements the higher-level *Firewall Change Procedure* (firewall_change_procedure.txt) by providing concrete implementation guidance for each platform in the JemTechnologies firewall estate (perimeter clusters, internal segmentation firewalls, and cloud-native security groups/NACLs).

2. Firewall Rule Implementation

2.1 Rule Object Standards

- Use named address objects and groups from the central object store (JemTech-ObjMgr); avoid inline literal IPs except for short-lived, single-host temporary rules.
- Service objects define port/protocol combinations; do not redefine common services (e.g., HTTPS-443) ad hoc — reuse the standard object library.
- Every rule must reference the originating change ticket in its description field, e.g. *CM-48213: appsvc to dbtier read replica*.

2.2 Rule Composition

- Specify source zone, destination zone, source object, destination object, service, action, and logging profile explicitly — no field left at platform default.
- Action is one of: allow, deny, drop (silent), or reject (explicit refusal) — select deliberately, as drop vs. reject has operational and diagnostic implications.
- Where the platform supports application-layer identification (App-ID / L7 inspection), enable it for internet-facing and DMZ-facing rules.

2.3 Temporary Rules

Temporary rules (e.g., for a migration or short-term integration) must carry an explicit expiration date set in the rule scheduling object, and must be logged in the Firewall Rule Register with an owner and review date, per network_access_control.txt Section 5.2.

3. NAT (Network Address Translation)

3.1 NAT Types in Use

- Static NAT — one-to-one, used for published services with a fixed public address.
- Dynamic NAT / PAT — used for outbound internet access from internal segments via a shared pool or interface address.
- Destination NAT (DNAT) — used for inbound access to internal services published through the perimeter.

3.2 Implementation Guidance

- Document both pre-NAT and post-NAT address/port pairs in the change ticket — this is the single most common source of firewall-policy confusion during troubleshooting.
- Confirm whether the platform evaluates security policy against pre-NAT or post-NAT addresses, and build the corresponding policy rule against the correct object.
- Avoid overlapping NAT pools; run the NAT-conflict check in JemTech-ConfigLint before implementation.
- For DNAT rules publishing a new service, confirm a corresponding security policy rule exists — a NAT rule alone does not grant traffic passage on most JemTechnologies platforms.

4. ACLs

4.1 Router/Switch ACLs

- Applied at VLAN Layer-3 boundaries per `network_access_control.txt`; numbered or named consistently with the VLAN/ACL Matrix.
- Implicit deny is assumed at the end of every ACL; do not rely on an explicit final deny unless the platform requires it for logging purposes.

4.2 Cloud Security Groups and NACLs

- Security Groups are stateful and attached at the instance/ENI level; NACLs are stateless and attached at the subnet level — both must be reviewed together, as NACLs can silently block traffic that Security Groups appear to permit.
- Follow the same object-naming and change-ticket-reference conventions as on-premises rules (Section 2.1) for consistency across the hybrid estate.

5. Rule Ordering

5.1 First-Match Platforms

On first-match (top-down) platforms, rule position determines behavior. Insert new rules with care:

- Specific/narrow rules generally belong above broader rules that would otherwise shadow them.
- Deny/block rules intended to pre-empt a broader allow must be placed above that allow rule.
- After any insertion, re-run the rule-conflict analyzer to confirm no unintended shadowing was introduced.

5.2 Rule Base Hygiene

- Group related rules together with clear section headers/comments in the rulebase for maintainability.
- Quarterly rule cleanup: identify unused rules (zero hit count over 90 days) and route them through the standard removal change process rather than deleting ad hoc.

6. Logging

6.1 Required Logging

- All allow and deny actions are logged by default; disabling logging on any rule requires Network Security Lead approval and a documented justification.
- Log forwarding to JemSIEM must be verified as part of every change (see `firewall_change_procedure.txt` Section 4.3).

6.2 Log Content Standards

Logs must capture, at minimum: timestamp, source/destination IP and port, protocol, matched rule name, action taken, NAT translation (if applicable), and session ID. Devices producing logs missing any of these fields must be flagged for a configuration remediation ticket.

7. Validation

7.1 Pre-Deployment Validation

- Syntax and conflict validation in JemTech-ConfigLint prior to any commit.
- Peer review of the rule/NAT/ACL diff against the approved change ticket.

7.2 Post-Deployment Validation

- Positive test: confirm the intended traffic now passes, using controlled probes (jemtech-probe-01/02) and, where possible, the actual requesting system.
- Negative test: confirm traffic that should remain blocked is still blocked, particularly for rules that widen access to a shared object.
- Log verification: confirm matching log entries appear in JemSIEM within 5 minutes of test traffic, with the expected rule name and NAT translation.
- Adjacent system health check: monitor dashboards for related services for 15 minutes post-change to catch unintended impact from rule reordering or object reuse.

7.3 Sign-off

Post-deployment validation results are attached to the change ticket. For Normal and Emergency changes, the Network Security Lead reviews validation evidence before the ticket is marked complete, per `network_security_sop.txt` Section 6.